

Chapter 5: GPO Permissions/Files

1 The Concept: Group Policy Objects (GPOs)

Technical Concept: Configuration Management Vulnerabilities

A Group Policy Object (GPO) is a collection of settings used to configure users and computers centrally in Active Directory.

- **The Links:** GPOs are linked to Organizational Units (OUs); their settings apply to objects within those OUs.
- **Misconfigured Delegation:** By default, only Domain Admins can modify GPOs. However, improper delegation may grant "Authenticated Users" or specific low-privileged groups the right to edit a GPO.
- **The Attack Vector:** If an attacker can modify a GPO, they can add malicious start-up scripts or scheduled tasks that execute on every machine linked to that policy.
- **File Replacement:** If a GPO executes a file stored on a network share with weak NTFS permissions, an attacker can simply replace the legitimate file with a malicious one.

The Grand Hotel Analogy: The Unlocked Policy Manual

Imagine the hotel has a **Policy Manual** (*GPO*) that dictates how the staff should behave. This manual is kept in a central **Department Folder** (*OU Link*).

- **The Normal Rule:** Only the **General Manager** (*Domain Admin*) should be able to write new rules in the manual.
- **The Error (Delegation):** The Manager accidentally leaves a pen and the "Edit" key (*Write Permissions*) on the front desk, allowing any **Dishwasher** (*Authenticated User*) to grab them.
- **The Sabotage:** A malicious dishwasher adds a new rule: "*When the Head Chef arrives tomorrow morning, he must run this specific 'Safety Check' script.*"
- **The Result:** Because the Chef (*The Computer/User Object*) follows the official manual, he executes the sabotaged rule without question, giving the attacker control over his actions.

2 Attack Execution: GPO Abuse

2.1 Phase 1: Direct GPO Abuse

In this lab scenario, we assume the compromised user (**Bob**) has the necessary permissions to edit a GPO directly.

>_ Terminal: On DC1 (via Jump from WS001)

1. Identify a GPO linked to an OU containing target computers.
2. Right-click GPO -> Edit.
3. Navigate to Computer Configuration -> Policies -> Windows Settings -> Scripts.
4. Add a Start-up script or a Scheduled Task pointing to a malicious payload.

3 Detection: Monitoring Directory Service Changes

Technical Concept: Event ID 5136 (GPO Modified)

When Directory Service Changes auditing is enabled, Active Directory generates **Event ID 5136** whenever a GPO is modified.

- **The Indicator:** A red flag should be raised if a user who is not expected to have GPO modification rights appears in these logs.
- **The Automation:** Security teams can automate scripts to monitor these logs in real-time and alert on unauthorized changes.

4 Honeypot

Organizations can intentionally leave a "weak" GPO in the environment to lure attackers into revealing themselves.

5 Prevention

Technical Concept: Hardening Strategies

- **Restrict Permissions:** Lock down GPO modification rights to a very small, specific group of accounts rather than all Domain Admins.
- **Audit Network Shares:** Ensure that any files (scripts/installers) deployed via GPO are stored on shares with strict NTFS permissions, preventing non-admin users from replacing them.
- **Regular Reviews:** Automatically audit GPO permissions hourly to detect and revert any unauthorized changes.